MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 045 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

COLUMN · BUYING OUTSIDE HELP

CMMC Consultant, RPO, MSP, or vCISO: Who Owns Your Program?

Hiring a CMMC consultant? An RPO, an MSP, and a vCISO do three different jobs, and none of them can sign for you. What to ask each before you buy.

BY **MATTHEW DAVIS** READING TIME · 6 MIN CMMC · CONSULTANTS · VCISO · MSP · GOVERNANCE

Picture a defense contractor with sixty employees and one overworked IT lead. Sooner or later it receives three proposals that look like answers to the same question. One comes from a CMMC consultant with a Registered Provider Organization badge on its letterhead. One comes from the managed service provider that already runs the network. One offers a virtual CISO, eight hours a week. Each promises to take CMMC off the owner's desk, and that promise is the problem, because the thing the owner most wants to buy - someone else to own the program - is the one thing none of them is permitted to sell.

Here is the plain answer for anyone deciding how to choose a CMMC consultant. The three do different jobs. An RPO helps you implement the requirements. An MSP operates your systems and, in doing so, becomes an External Service Provider inside your assessment scope. A virtual CISO supplies part-time security leadership: the judgment calls, the risk register, the policy decisions. None of them owns the outcome. Under 32 CFR 170.22, the Affirming Official who attests to continuing compliance is a senior representative from within the organization being assessed, and that signature carries personal weight no contract can pass along to a vendor.

Start with the credential most often mistaken for a guarantee. A CMMC RPO is a registration run by the Cyber AB, not a role the regulation creates; Part 170 never mentions it. To earn the listing, a firm signs an RPO agreement and the Cyber AB Code of Professional Conduct, clears an organizational background check, and associates at least one Registered Practitioner who has completed Cyber AB training and passed its exams. That tells you the firm answers to a code of conduct and has put at least one person through a baseline curriculum. It does not tell you whether the system security plan the firm writes will survive an assessor, whether its own house is in order, or whether you will pass. And RPOs do not conduct certification assessments. Confirm the listing on the Cyber AB Marketplace rather than trusting the logo.

That distinction between preparing and assessing is written into the rule. 32 CFR 170.8(b)(17)(ii)(G) requires the Cyber AB to bar members of the CMMC ecosystem from any Level 2 certification assessment of an organization they consulted to prepare for any CMMC assessment within the previous three years. The Code of Professional Conduct applies that bar to the C3PAO and to every member of its assessment team, and reads "consulting" broadly enough to include sold templates. The practical consequence runs both ways. A firm that offers to get you ready and then certify you is offering something the rules forbid. And a consultant whose people later join an assessment team has taken those people off your assessment for three years. Third-party assessments are suspended while the CMMC Reform Task Force completes its review, but the independence rule sits in the regulation, not in the pause.

The MSP for CMMC is a different animal, because its job is operating, not advising. MacZine has already made the case for treating an MSP with administrative access as an in-scope provider and for reading its customer responsibility matrix before signature; that argument does not need rerunning here. For ownership the point is narrower: an MSP that writes the security plan describing its own controls is grading its own work. No rule forbids the arrangement, but it leaves nobody on your side of the table whose job is to ask whether the MSP is doing what the plan says.

FIELD COPY
ISSUE Nº 045
CMMC

3

YEARS A CONSULTANT WHO PREPARED YOU FOR ANY CMMC ASSESSMENT IS BARRED FROM YOUR LEVEL 2 CERTIFICATION ASSESSMENT - 32 CFR 170.8(B)(17)(II)(G)

1

AFFIRMING OFFICIAL PER ORGANIZATION, A SENIOR REPRESENTATIVE FROM WITHIN IT - 32 CFR 170.22

0

TIMES 32 CFR PART 170 MENTIONS A REGISTERED PROVIDER ORGANIZATION - THE RPO IS A CYBER AB PROGRAM, NOT A REGULATORY ROLE

The virtual CISO for defense contractors comes closest to what the owner actually wants and deserves the most scrutiny. No registration governs it and Part 170 does not mention it; the title means whatever the contract says. A good one owns the risk register, makes vendor and architecture calls, runs incident command, and briefs leadership on where the program stands. That is judgment, and judgment is what small contractors most often lack. But a vCISO recommends. The person who signs still has to decide.

You can outsource the labor, the tooling, and even the judgment. You cannot outsource the signature.

Everything a buyer should ask follows from that sentence, and the questions are the same for all three provider types. First, what do you keep? The SSP source files, the POA&M, the policy set, and the evidence repository should live in your tenant under your account, not in a portal you lose access to when the invoice stops. Second, who writes and who approves? An outsider can draft the security plan; someone inside the company with authority has to approve it, and should be able to explain it to an assessor without the author in the room. Third, what does leaving look like? Ask for the handover in writing before you start: which credentials rotate, which documents transfer, how long evidence is retained, and who holds the administrator accounts on the last day.

◆ A TEMPLATE IS ADVICE, TOO

The Cyber AB Code of Professional Conduct (v2.0, December 2024) works through a C3PAO that once sold an organization a package of CMMC implementation templates and never consulted in person. The Code still treats the templates as advisory activity and the conflict as one to avoid - the assessor would be grading its own product.

Two phrases in a proposal should end the conversation. The first is any guarantee of certification. The Code of Professional Conduct directs its members, RPOs included, to forgo guarantees of assessment results, money-back offers among them. A firm bound by that Code that promises you will pass is either unaware of its own obligations or indifferent to them. The second is the "CMMC certified" consultant. Organizations earn a CMMC status for their own systems, which says nothing about their ability to build yours. Individuals can hold real credentials, the CMMC Certified Professional defined in 32 CFR 170.13 among them, and the regulation requires the Code to bar members from misrepresenting credentials or exaggerating the services they are authorized to deliver. Ask which credential, held by which named person, and verify it.

MacTech sits on the leadership side of this map. Its Market lists a Fractional CISO retainer built around the risk register, policy ownership, vendor and incident decisions, and a quarterly leadership readout, and the firm says plainly that it prepares clients for a C3PAO rather than scheduling one. The rest of the service-disabled veteran-owned firm's lines are on its SDVOSB cybersecurity services page. Before hiring anyone, though, run a readiness check so you know what you are buying help with.

The owner who received three proposals does not need to pick the one that promises to take CMMC away. The right purchase is whichever combination makes the person who signs competent to sign - an RPO for the build, an MSP held to its matrix, a vCISO to sharpen the decisions. The program was always going to have an owner. The only open question is whether that owner knows what they own. ◆